

Security+ 3.2 · Firewall Types

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 3.2** —
Firewall Types (8:00) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Firewall evolution: stateless ACLs filter per-packet; stateful firewalls remember the connection state; NGFWs add application awareness, user identity, threat intelligence, and SSL inspection; UTM combines NGFW + IPS + AV + anti-spam in a single appliance; WAF protects HTTP/S web applications (SQLi, XSS, CSRF).

High-Yield Core Concepts Tested on Exam

- Stateful remembers the connection; stateless filters per packet
- NGFW = stateful + application + user + threat intelligence
- WAF (Layer 7) protects the web app; NGFW protects network traffic
- UTM = NGFW + IPS + AV + anti-spam in one appliance
- WAF targets web-specific attacks: SQLi, XSS, CSRF

Exam Tips & Classic Scenarios

- 'application-aware firewall' = NGFW
- 'inspects HTTP for SQL injection' = WAF
- 'application-level firewall for the web server' = WAF

Typical Exam Scenario: An application-level firewall is needed to protect a web server from SQL injection and XSS. Deploy a WAF (Web Application Firewall), which operates at Layer 7 and inspects HTTP/S traffic.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 3.2 — Firewall Types)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **WAF:** Web Application Firewall: Layer 7 security inspection appliance/service that inspects and filters HTTP/HTTPS payloads against OWASP Top 10 exploits such as SQL Injection, XSS, and CSRF.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Which network security device operates at the application layer (Layer 7) and can inspect HTTP/HTTPS content?

- A)** Traditional stateful firewall
- B)** Web Application Firewall (WAF)
- C)** Layer 2 switch
- D)** Hub

2. Difference between IDS and IPS:

- A)** IDS detects and alerts; IPS detects and BLOCKS
- B)** They are the same thing
- C)** IDS is disk-based; IPS is network-based
- D)** IPS only logs

3. What is the main difference between IDS and IPS?

- A)** IDS blocks attacks, IPS only detects
- B)** IDS only detects and alerts, IPS can actively block
- C)** IDS is physical, IPS is virtual
- D)** IDS operates at layer 2, IPS at layer 3

4. Corporate scenario (Firewall Types): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'Stateful remembers the connection; stateless is per packet'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Stateful remembers the connection; stateless is per packet...
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Firewall Types): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'NGFW = stateful + application + user + threat intelligence'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: NGFW = stateful + application + user + threat intelligence...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Firewall Types): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'WAF (L7) protects the web app; NGFW protects network traffic'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: WAF (L7) protects the web app; NGFW protects network traffic...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Firewall Types): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'application-aware firewall' = NGFW. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'application-aware firewall' = NGFW...

8. Corporate scenario (Firewall Types): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'inspects HTTP for SQL injection'=WAF. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'inspects HTTP for SQL injection'=WAF...
- D)** Allow shared access among administrators with generic credentials

9. Corporate scenario (Firewall Types): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'application-level firewall for the web server'=WAF. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'application-level firewall for the web server'=WAF...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Firewall Types): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'Stateful remembers the connection; stateless is per packet.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Stateful remembers the connection; stateless is per packet...
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Web Application Firewall (WAF).

✓ **Why it's correct:** A **Web Application Firewall (WAF)** is a security device that operates at the application layer (Layer 7 of the OSI model) and is designed to inspect HTTP/HTTPS traffic, protecting web applications against attacks such as SQL injection, cross-site scripting (XSS), cross-site request forgery (CSRF), among others. It analyzes the content of requests and responses, applying rules based on signatures or anomalous behavior. In the CompTIA Security+ (SY0-701) syllabus, WAF is explicitly cited as an application-layer security control to protect web servers. Therefore, it is the exact answer to the description.

✗ **Why the others are wrong:**

- *Traditional stateful firewall:* A traditional stateful firewall operates at the network and transport layers (Layers 3 and 4). It maintains a state table of connections and allows or blocks packets based on IP addresses, ports, and connection state. However, it does not inspect application-layer content (HTTP/HTTPS) and therefore cannot detect attacks like SQL injection or XSS. To inspect HTTP/HTTPS content, a next-generation firewall (NGFW) with deep packet inspection or a WAF would be required. Thus, the traditional stateful firewall does not meet the requirement of operating at the application layer and inspecting content.
- *Layer 2 switch:* A Layer 2 switch operates at the data link layer (Layer 2) and is responsible for forwarding Ethernet frames based on MAC addresses. It lacks application-level traffic inspection capabilities, let alone HTTP/HTTPS content. Its function is to connect devices within the same local network, segmenting collision domains. It is not a Layer 7 security device and cannot inspect content. Therefore, it is incorrect.
- *Hub:* A hub is a physical layer (Layer 1) device that simply repeats electrical signals to all ports, without any forwarding intelligence or inspection. It does not operate at higher layers and offers no security functionality, much less HTTP/HTTPS content inspection. Hubs are obsolete and replaced by switches. Hence, it does not apply to the context of application-layer security.

2) A — IDS detects and alerts; IPS detects and BLOCKS.

✓ **Why it's correct:** The fundamental difference between IDS (Intrusion Detection System) and IPS (Intrusion Prevention System) lies in the action taken after detecting an intrusion. IDS monitors network traffic or system activities for malicious patterns and, upon detection, generates alerts for administrators to investigate. It is passive and does not interfere with data flow. IPS, on the other hand, is active: besides detecting, it blocks or prevents malicious activity in real time, dropping packets, resetting connections, or applying other countermeasures. This distinction is tested in the Security+ (SY0-701) Security Architecture and Design domain, objective 3.2, which covers network security technologies.

✗ **Why the others are wrong:**

- *They are the same thing:* IDS and IPS are distinct technologies with different functions and network placements. IDS is a passive detection system, typically connected to a SPAN port or TAP, analyzing copies of traffic. IPS is an active prevention system, installed inline with the data flow, capable of blocking attacks. Claiming they are the same ignores their operational differences, network impact, and incident response, and contradicts established information security definitions.
- *IDS is disk-based; IPS is network-based:* This statement is incorrect because both can operate on network or host. There are HIDS (Host-based IDS) and HIPS (Host-based IPS), which monitor activities on a single device, including system calls and file integrity. Similarly, NIDS (Network-based IDS) and NIPS (Network-based IPS) analyze network traffic. The distinction is not between

disk and network, but between passive detection and active prevention. The alternative confuses monitoring scope with response mechanism.

- *IPS only logs*: This description applies more to an IDS, which typically logs events and emits alerts. IPS is not limited to logging; its primary function is to actively block intrusion attempts. Although many IPS also generate logs for auditing, its defining characteristic is the ability to prevent attacks in real time, taking actions such as dropping malicious packets or terminating sessions. Reducing IPS to a mere log recorder underestimates its critical active protection function.

3) B — IDS only detects and alerts, IPS can actively block.

✓ **Why it is correct:** The correct answer is 'IDS only detects and alerts, IPS can actively block'. In the CompTIA Security+ ecosystem, an IDS (Intrusion Detection System) is a passive monitoring system that inspects network traffic or host activities for attack signatures or behavioral anomalies. Upon identifying a suspicious match, it generates an alert (log, SNMP notification, syslog) for the security team but does not interfere with the data flow. An IPS (Intrusion Prevention System) operates actively and inline (in the traffic path), capable of dropping malicious packets, resetting TCP connections, blocking IP addresses, or applying mitigation policies in real time. The fundamental difference lies in placement and action capability: IDS is an out-of-band sensor (SPAN/TAP), while IPS is an inline device that applies automatic countermeasures. This distinction is crucial for the security objective: detect versus prevent.

✗ **Why the others are wrong:**

- *IDS blocks attacks, IPS only detects*: This option completely reverses the functions. An IDS is by definition a passive detection system: it lacks mechanisms to block traffic because it is typically connected to a switch SPAN port or network TAP, receiving only copies of packets. Its function is to analyze and alert. An IPS, on the other hand, is designed for active prevention, operating inline and applying blocking actions. Therefore, the statement is factually wrong and contradicts CompTIA's conceptual model, which emphasizes the difference between detection (IDS) and prevention (IPS).
- *IDS is physical, IPS is virtual*: This option confuses implementation nature with function. Both IDS and IPS can be implemented as physical appliances, virtual machines, host-based software (HIDS/HIPS), or cloud solutions. The correct classification does not depend on physical or virtual medium, but on response capability: passive detection (IDS) versus active prevention (IPS). CompTIA Security+ does not associate IDS with physical hardware and IPS with virtualization; that distinction is irrelevant to the functional definition of the systems.
- *IDS operates at layer 2, IPS at layer 3*: This option attempts to associate the systems with specific OSI model layers, which is incorrect. IDS and IPS can operate at multiple layers, depending on configuration and analysis type. For example, a network-based IDS (NIDS) can inspect layer 3 (IP) and layer 4 (TCP/UDP) headers, as well as layer 7 (application) payloads. An IPS can also act at various layers, including layer 2 (Ethernet frames) in bridge mode. The statement is a misleading simplification and does not reflect the real architecture of these systems, which are defined by their function (detection vs. prevention) and not by a fixed OSI layer.

4) C — Implement the corresponding solution: Stateful remembers the connection; stateless is per packet....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Firewall Types): Stateful remembers the connection; stateless is per packet. A stateful firewall tracks the state of active connections and makes filtering decisions based on the context of the traffic, while a stateless firewall inspects each packet in isolation without regard to connection state.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: This directly violates the

Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and it breaks compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) B — Implement the corresponding solution: NGFW = stateful + application + user + threat intelligence....

✓ **Why it's correct:** According to the official CompTIA Security+ exam objectives (SY0-701) for lesson 3.2 (Firewall Types): NGFW = stateful + application + user + threat intelligence.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who made critical changes or malicious commands.

6) B — Implement the corresponding solution: WAF (L7) protects the web app; NGFW protects network traffic....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Firewall Types): WAF (L7) protects the web app; NGFW protects network traffic.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) D — Implement the corresponding solution: 'application-aware firewall' = NGFW....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Firewall Types): 'application-aware firewall' = NGFW. A Next-Generation Firewall (NGFW) goes beyond traditional port/protocol inspection to include application awareness, deep packet inspection, intrusion prevention, and threat intelligence. The appropriate control is to implement the corresponding solution, which is an NGFW that can identify and control applications regardless of port, enforce policies based on users and content, and integrate with other security systems.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) C — Implement the corresponding solution: 'inspects HTTP for SQL injection'=WAF....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Firewall Types): 'inspects HTTP for SQL injection'=WAF.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) B — Implement the corresponding solution: 'application-level firewall for the web server'=WAF....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Firewall Types): 'application-level firewall for the web server'=WAF. A Web Application Firewall (WAF) inspects HTTP/HTTPS traffic at the application layer to protect web servers from attacks like SQL injection and XSS.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: Stateful remembers the connection; stateless is per packet....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Firewall Types): Stateful remembers the connection; stateless is per packet. A stateful firewall maintains a state table of active connections and makes filtering decisions based on the context of the traffic, while a stateless firewall inspects each packet in isolation without regard to connection state.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.